

RFC-0004

Estratégia de Evolução para Clientes Enterprise

(Isolamento Forte, Compliance e Hardening)

Status: Aprovado e Atualizado (v1.1)

Autor: Equipe de Arquitetura

Data: 07/05/2026

Depende de: RFC-0001, RFC-0002, RFC-0003, RFC-0005

1. Contexto

O MVP (Tier 1) foi projetado com:

- Banco de dados único.
- Múltiplos Schemas Funcionais** (Domínio global pessoa e domínio isolado folha_ponto).
- Realm corporativo único no Keycloak.
- Isolamento lógico por `organizacao_id`.

Esse modelo é perfeitamente adequado para o *early stage*, clientes pequenos/médios e cenários com governança unificada.

Entretanto, clientes Enterprise (especialmente B2G, grandes secretarias e corporações) exigirão:

- Isolamento de infraestrutura mais forte (Single-Tenant).
- Garantias formais de compliance à LGPD.
- Governança e residência de dados (Data Sovereignty).
- SLAs dedicados.
- Hardening de segurança severo.

Este RFC define a evolução arquitetural para atender a essas contas Enterprise **sem quebrar a base de código e sem ferir os princípios de Identidade Canônica da plataforma**.

2. Objetivos

- Permitir múltiplos níveis de isolamento (Tier 1 a Tier 3) sem *fork* do monolito.
- Atender aos requisitos regulatórios rigorosos de clientes corporativos e governamentais.
- Permitir customizações Enterprise preservando o uso estrito de *Lightweight Tokens*.
- Manter o CPF como a única e imutável raiz de Identidade Canônica, não importando a

- divisão de IdPs.
5. Garantir escalabilidade horizontal e segregação de Storage.
-

3. Modelo de Segmentação de Clientes

A arquitetura do sistema prevê três níveis topológicos de isolamento:

3.1 Tier 1 — Shared (MVP - Atual)

- Banco compartilhado.
- Schemas funcionais padrão (pessoa e folha_ponto).
- Realm único no IAM.
- Isolamento lógico via *query filtering* (*organizacao_id*).

3.2 Tier 2 — Isolamento Intermediário (Schema-per-Tenant)

- Banco compartilhado.
- Schema global *pessoa* (unificado).
- **N Schemas de Negócio:** Criação de um schema *folha_ponto_{tenant}* dedicado para cada cliente Enterprise.
- Realm dedicado opcional no Keycloak.

3.3 Tier 3 — Enterprise Dedicated (Sovereign)

- Banco de dados físico dedicado exclusivamente ao cliente.
 - Infraestrutura de contêineres e redes (VPC) dedicada.
 - Realm exclusivo ou IAM On-Premise do cliente.
 - Criptografia KMS dedicada (BYOK - *Bring Your Own Key*).
-

4. Evolução do Multi-Tenancy (Gestão de Schemas)

A evolução do SaaS exige transições fluídas entre os Tiers de banco de dados:

4.1 Fase 1 (MVP)

```
1 Database Postgres
├─ Schema: pessoa (Global)
└─ Schema: folha_ponto (Multi-tenant lógico via organizacao_id)
```

4.2 Fase 2 — Schema por Tenant

```
1 Database Postgres
├─ Schema: pessoa (Global - Identidade Canônica Centralizada)
├─ Schema: folha_ponto_orgaoA (Isolamento Estrutural)
└─ Schema: folha_ponto_orgaoB (Isolamento Estrutural)
```

Benefícios: Backup por tenant, *Restore* pontual, Migração seletiva para infra dedicada. **Requisito de Software:** Implementação de um *TenantResolver* dinâmico no Hibernate/Spring Boot que

intercepte a rota e aponte para o Schema correto em tempo real.

5. Evolução do IAM e Resiliência da Identidade Canônica

5.1 O Desafio do Realm por Cliente Enterprise

Grandes clientes frequentemente exigem a gestão de seus próprios Realms no Keycloak para aplicar Branding próprio, gerir federações específicas de LDAP/SAML ou aplicar políticas de senha que divergem do padrão global da plataforma.

5.2 A Resiliência da Tabela `identidade_acesso`

Se o cliente migrar para o Tier 2 ou Tier 3 e exigir um Realm próprio, a nossa arquitetura continua estruturalmente blindada. O usuário do cliente autenticará no novo Realm dedicado e receberá um novo identificador técnico (`sub` inédito). Ao tentar acessar a plataforma, o Spring Boot não o reconhecerá de imediato. A aplicação executará o protocolo padrão de *Onboarding Obrigatório* (*Custom SPI + Action Tokens*). O usuário fará a Validação 2x2 informando o seu CPF e sua foto. O sistema, ao validar os dados no Datavalid/Serpro, atrelará pacificamente o "novo sub do Realm Enterprise" ao CPF já existente na tabela global `pessoa.identidade_acesso`. O histórico do servidor público permanece intacto, transcendendo as barreiras técnicas de IAM.

6. Compliance, LGPD e Governança

6.1 Política Intransponível: Descarte da Mídia Fonte

É comum em contratos Enterprise e B2G que gestores exijam o armazenamento das fotos brutas de seus servidores para fins de "dossiê" ou auditoria visual. A plataforma estabelece a **diretriz inegociável do Descarte da Mídia Fonte**. Independentemente de tratar-se do Tier 1 ou do Tier 3, a plataforma jamais salvará as fotografias faciais rasterizadas (`.jpg` / `.png`) em discos rígidos ou storages perenes. O sistema processa o *Hash Biométrico* (vetor matemático) na volatilidade da memória RAM e descarta a imagem imediatamente após a extração, cumprindo o princípio da minimização da LGPD e erradicando riscos criminais em caso de vazamentos.

6.2 Criptografia de Dados Sensíveis

Os vetores matemáticos biométricos, os IPs nas tabelas de auditoria, e as geolocalizações precisas de dispositivos devem possuir Criptografia em Repouso (*Column-Level Encryption* ou *Transparent Data Encryption*), protegidos através de chaves KMS geridas pela plataforma (Tier 1/2) ou pelo cliente final (BYOK no Tier 3).

6.3 Direito do Titular e Consentimento

A infraestrutura (por meio da tabela `folha_ponto.consentimento`) assegurará autonomia na:

- Revogação do consentimento de uso da biometria.

- Solicitação formal de exclusão lógica controlada.
 - Exportação (dump) dos dados geográficos vinculados àquele CPF.
-

7. Hardening de Segurança Enterprise

Para a migração de clientes à arquitetura de alto isolamento, devem-se implementar as seguintes camadas:

- **Borda:** Web Application Firewall (WAF) com restrição rigorosa por geolocalização.
 - **Rede:** Rate Limiting por tenant no API Gateway (prevenção de ataque de exaustão ruidoso).
 - **Storage:** Isolamento de Storage de ativos estáticos utilizando *Buckets S3 / Filer* segregados por tenant.
-

8. Observabilidade e Auditoria Avançada

Operações Enterprise exigem transparência técnica total. O sistema deve suportar:

- A tag obrigatória do `tenant_id` atrelada a cada linha de log da aplicação.
 - Tracing distribuído (OpenTelemetry/Jaeger).
 - Exportação de eventos imutáveis (registrados na tabela `folha_ponto.log_auditoria`) para o SIEM (Security Information and Event Management) do órgão cliente via *Webhooks* seguros.
-

9. Customizações Enterprise e Blindagem de Tokens

9.1 Customização sem *Fork*

O core de domínio permanece único e fechado. Clientes que solicitarem regras específicas de antifraude ou jornada serão atendidos por configurações isoladas (ex: Tabela `tenant_configuration`), controlando variáveis como `feature_flags`, `biometric_threshold` e `geofence_policy`.

9.2 A Blindagem de Lightweight Tokens (Diretriz Crítica)

Mesmo perante pressões de integração de sistemas legados dos clientes Enterprise, **sob nenhuma hipótese a arquitetura permitirá a injeção de dados sensíveis (PII, CPF, Endereços, Hashes Biométricos ou Permissões Complexas) dentro do *payload* do Token JWT**. Os acessos permanecerão sob a restrição de *Lightweight Access Tokens*. Todo enriquecimento de perfil ou validação granular (ABAC/PBAC) para esses clientes será resolvido internamente pelo banco de dados do Spring Boot através do modelo *Fetch On-Demand*, prevenindo roubo de sessões e violação massiva da LGPD nos navegadores locais.

10. Escalabilidade

- **Aplicação:** Completamente *Stateless*. Escalabilidade horizontal facilitada pelos tokens OIDC e pela engine interna baseada no banco.
 - **Banco de Dados:** Preparação nativa para instâncias de *Read Replicas* voltadas à extração pesada de relatórios (ex: Folha de Ponto Mensal do órgão).
-

11. Decisão Estratégica e Roteiro

A arquitetura do MVP atual no Spring Boot e PostgreSQL já deve nascer com os padrões corretos de injeção de dependência e isolamento.

1. O acesso a dados no schema `folha_ponto` já deve exigir nativamente a injeção condicional do `organizacao_id`.
2. A abstração das chamadas ao SeaweedFS (S3) já deve considerar o prefixo de pastas virtuais dinâmicas por locatário no *Filer*.

A decisão motriz desta RFC é: **Preparar as abstrações lógicas no código (Domain-Driven Design e Ports & Adapters) agora, para evitar migrações e refatorações traumáticas quando o primeiro contrato Enterprise ou Governamental exigir o seu banco de dados e bucket isolados.**